Penetration Testing Report

Mediroza General Hospital

Client: Mediroza General Hospital

Target: https://medirozahospital.com

Engagement Type: Black-box Penetration Test

Program: NetworkWalks Cybersecurity Internship — Batch B082, Week 4

Duration: 3 Days

Report Date: 07th September 2026

Prepared By: Anaam Umar

Supervised By: Mr. Waqas Karim, NetworkWalks

Authorisation: Written permission granted by client for this engagement

CONFIDENTIAL — This report is conducted in a controlled environment for educational purposes only. This engagement was fully authorised in writing by the client. These techniques must never be applied to any system without explicit written permission from the owner.

1. Executive Summary

This report was prepared as part of a hands-on penetration testing engagement conducted under the NetworkWalks Cybersecurity Internship Program (Batch B082, Week 4), under the supervision of Mr. Waqas Karim. The engagement simulated a real-world black-box penetration test against Mediroza General Hospital's public-facing web application at https://medirozahospital.com. The objective was to identify exploitable vulnerabilities, demonstrate their real-world impact, and provide actionable remediation guidance, following the same methodology and reporting standards expected of a professional penetration testing engagement.

Over this assessment, I identified multiple critical and high-severity vulnerabilities that, when chained together, resulted in a complete compromise of patient confidentiality and exposure of sensitive corporate data. The key findings are summarised below:

- An authentication bypass vulnerability in the patient portal login mechanism allowed unauthenticated access to the restricted patient area, resulting in the retrieval of three confidential patient pathology lab reports (PDF files).
- The retrieved PDF files were protected by weak, guessable passwords, which were successfully cracked, fully exposing patient names, dates of birth, and detailed medical test results.
- A misconfigured web server exposed directory listings on multiple restricted paths (/staff/ and /old/), which in turn exposed a full, unauthenticated SQL database backup (mediroza_db_backup_2019.sql) containing the personal details, national ID numbers, and monthly salaries of 30 hospital staff members, as well as the complete shareholder equity register of the hospital.
- robots.txt was found to explicitly list the sensitive directory names, effectively acting as a signpost to an attacker despite intending the opposite.

Taken together, these findings represent a severe and immediate risk to Mediroza General Hospital. The exposure includes protected health information (PHI), personally identifiable information (PII), and confidential corporate financial and ownership data. This combination creates significant risk of regulatory non-compliance (e.g., data protection legislation such as POPIA), reputational damage, identity theft, and financial fraud against both patients and staff.

NetworkWalks recommends immediate remediation of all findings detailed in Section 3, prioritising the Critical and High severity issues, followed by a full review of server configuration and access-control practices across the environment.

Finding	Milestone	Overall Risk
Authentication Bypass (Login SQL Injection)	M1	Critical
Weak PDF Encryption / Crackable Passwords	M2	High
Exposed Database Backup via Directory Listing	M3	Critical
Information Disclosure via robots.txt	M3	Low

2. Scope and Methodology

2.1 Target

https://medirozahospital.com — the public-facing web application and associated infrastructure of Mediroza General Hospital.

2.2 Type of Engagement

Black-box penetration test. No credentials, source code, or internal documentation were provided to the testing team prior to the engagement. All findings were derived independently through reconnaissance and testing.

2.3 Rules of Engagement

- Testing was limited strictly to the target domain (medirozahospital.com) and its subpaths.
- No social engineering was performed against staff or patients.
- No denial-of-service (DoS) testing was performed against the live production environment.
- All testing was conducted under written authorisation provided by the client.

2.4 Tools Used

The following tools and techniques were used during the penetration testing assessment:

- **Kali Linux** — Primary penetration testing environment used to perform the assessment and security testing activities.
- **curl** — HTTP request inspection, response/header analysis, and retrieval of accessible files from the target web application.
- **Web Browser (Manual Testing)** Manual inspection of the web application, patient portal login functionality, authentication testing, and SQL injection testing.
- **robots.txt** — Analysis of the website's robots.txt file to identify references to potentially restricted or sensitive directories.
- **NetworkWalks Hash Calculator** (networkwalks.com/hash-calculator) — Used to generate and identify hash values during the password-cracking process.
- **NetworkWalks Password Cracker** (networkwalks.com/password-cracker) — Used to recover the weak passwords protecting the retrieved PDF files.
- **exiftool / strings** — Used for metadata inspection and analysis of embedded or readable content within the retrieved PDF files.

2.5 Methodology Overview

Testing followed a standard black-box methodology: passive and active reconnaissance, enumeration of exposed content, vulnerability identification, exploitation to demonstrate real-world impact, and post-exploitation analysis to identify any further exposures. Each phase is documented in detail in Section 3.

2.6 Limitations

As this was a black-box assessment conducted within a fixed 3-day window, testing focused on the areas of highest likely impact identified during reconnaissance rather than an exhaustive review of every application endpoint. Additional vulnerabilities may exist outside the scope of this engagement.

3. Findings and Proof of Exploitation

This section documents each finding in the order it was discovered during the engagement, mapped to the corresponding project milestone (M1–M3). Each finding includes the discovery method, proof of exploitation, and supporting evidence.

3.1 Finding 1 — Authentication Bypass via SQL Injection in Patient Portal Login (M1)

Severity: Critical

Affected Component: /patient/login.php

Description

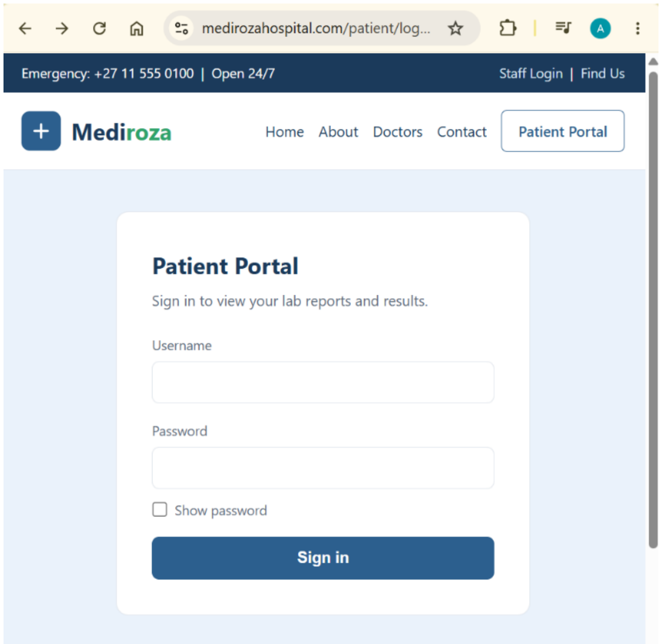
The patient portal login form was found to be vulnerable to SQL injection, allowing complete authentication bypass without valid credentials. This granted unauthenticated access to the restricted /patient/portal.php area and the confidential patient records contained within it.

Steps to Reproduce

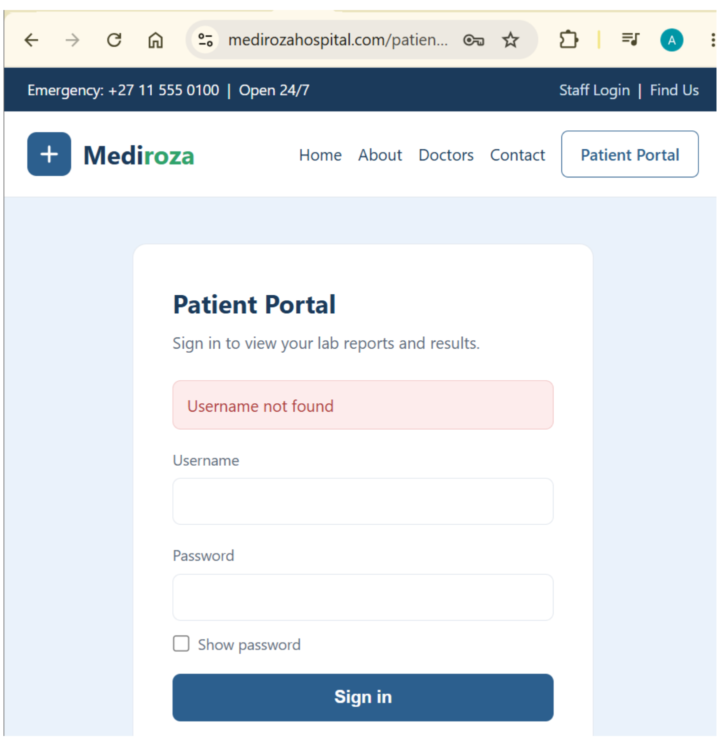
- 1. Performed initial reconnaissance against the target using curl to review server headers and response behaviour.

- 2. Enumerated hidden directories and pages using Robots.txt against the common wordlist.

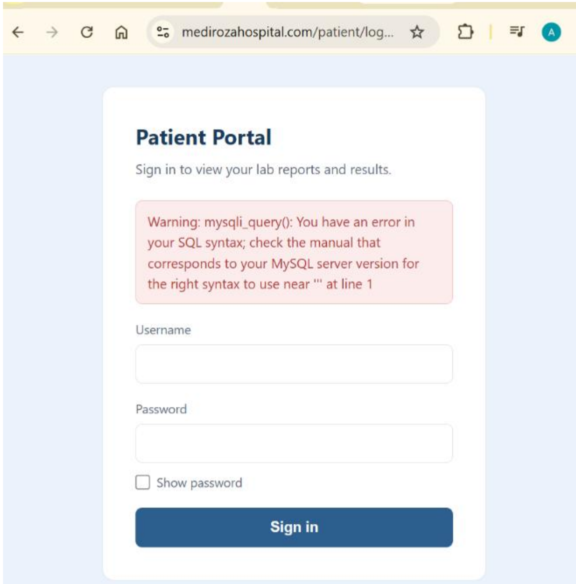
- 3. Located and accessed the patient area login page.



- 4. Tested the login form with a normal, invalid credential pair to establish baseline (expected failure) behaviour.

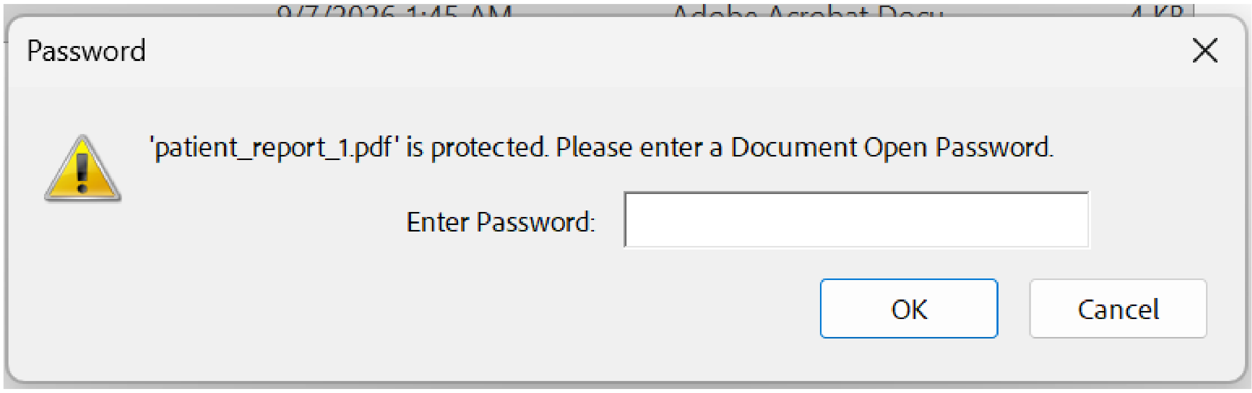


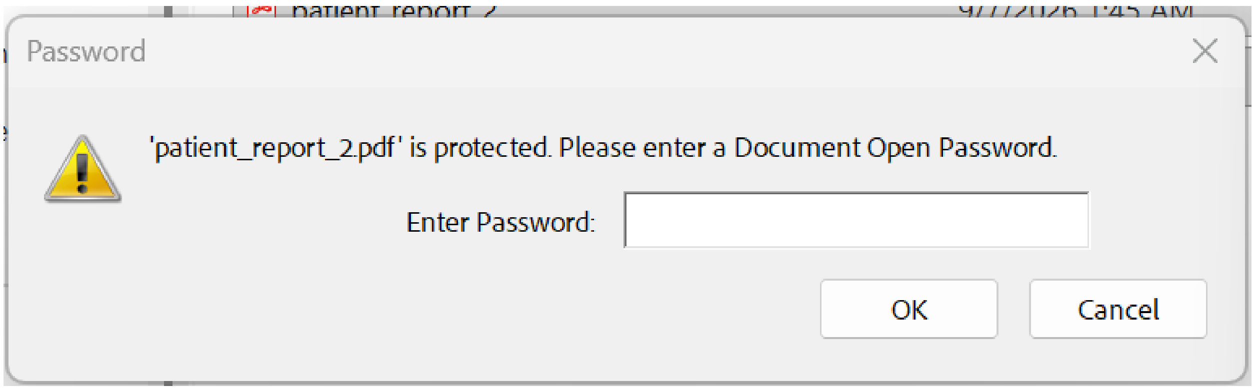
- 5. Tested the username/password fields for SQL injection, submitting a crafted payload designed to manipulate the underlying authentication query.

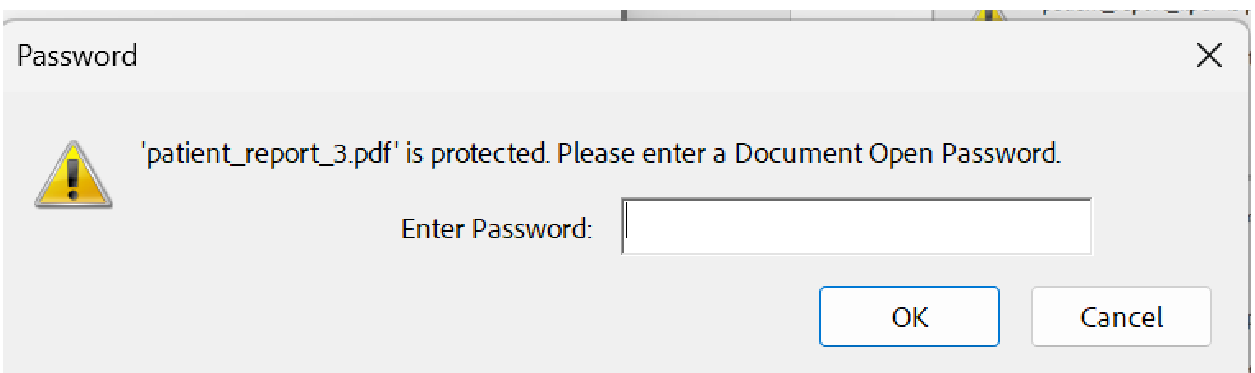


- 6. The crafted payload successfully bypassed authentication, logging in without valid credentials.

- 7. Located and retrieved the three confidential patient lab report PDFs from within the portal.







Impact

An unauthenticated attacker can fully bypass patient portal authentication and access any confidential patient medical record stored behind this login mechanism, without needing any valid credentials. This constitutes a complete breach of patient confidentiality and a serious violation of data protection obligations.

3.2 Finding 2 — Weak Encryption on Retrieved Patient PDF Files (M2)

Severity: High

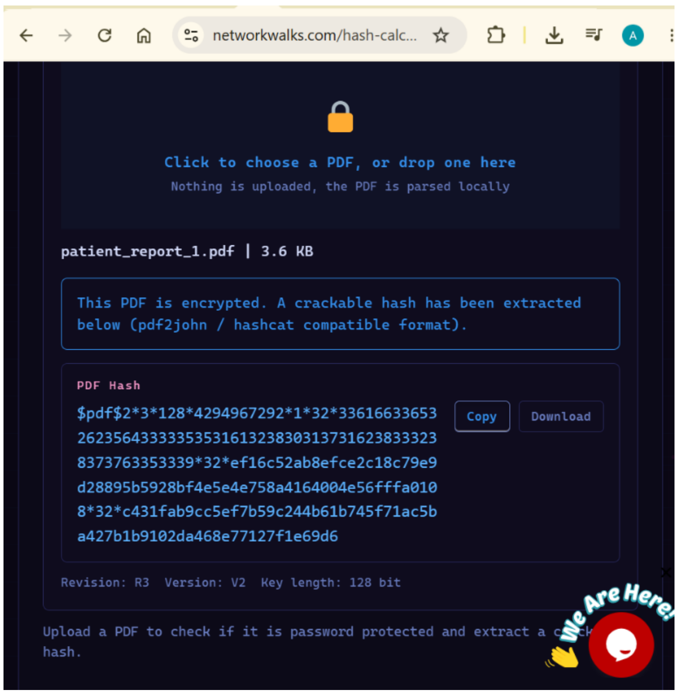
Affected Component: Patient_Report_1.pdf, Patient_Report_2.pdf, Patient_Report_3.pdf

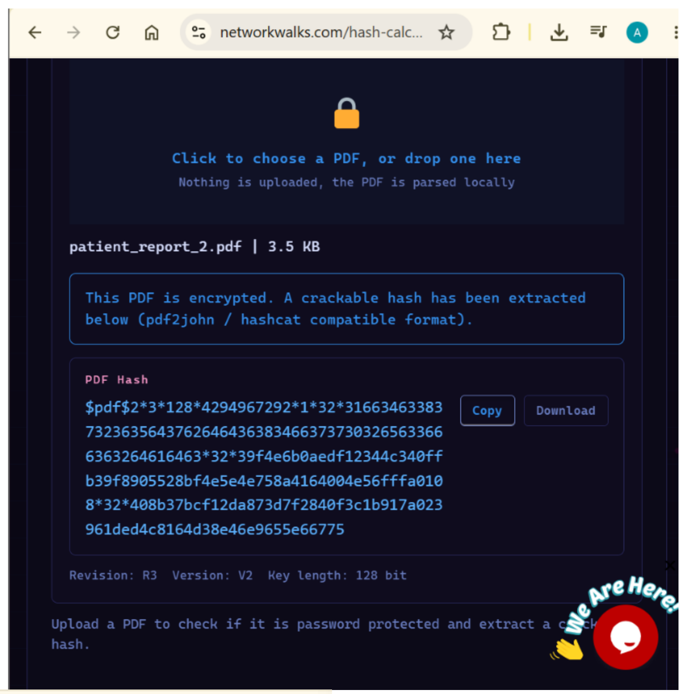
Description

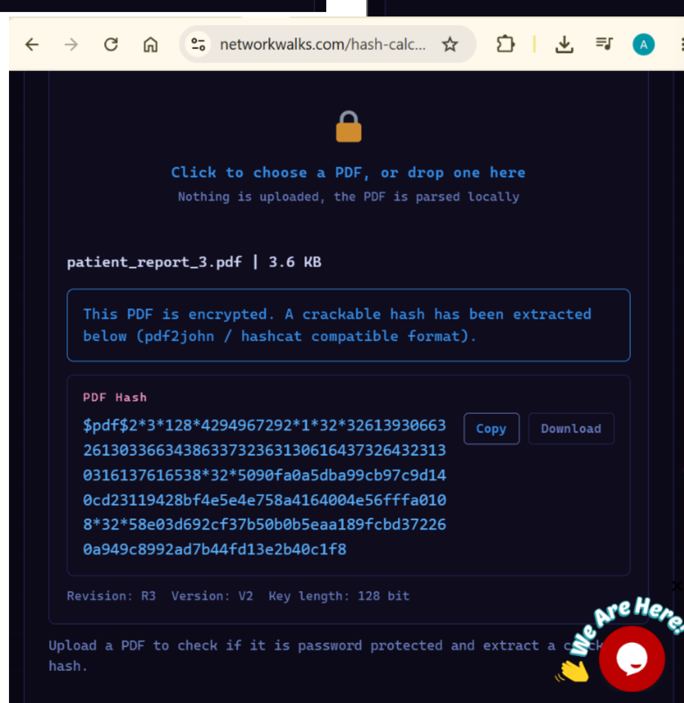
The three PDF lab reports retrieved in Finding 1 were password-protected; however, the passwords used were weak and were successfully recovered through hash analysis and password-cracking techniques, fully exposing the encrypted contents of each file. Each file required a distinct password, indicating passwords were not centrally/strongly managed.

Steps to Reproduce

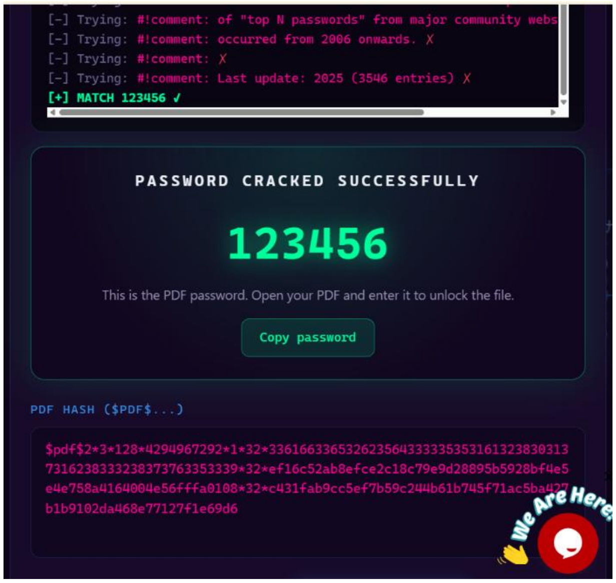
- 1. Extracted/generated the hash value associated with each PDF's password protection using the NetworkWalks Hash Calculator tool.

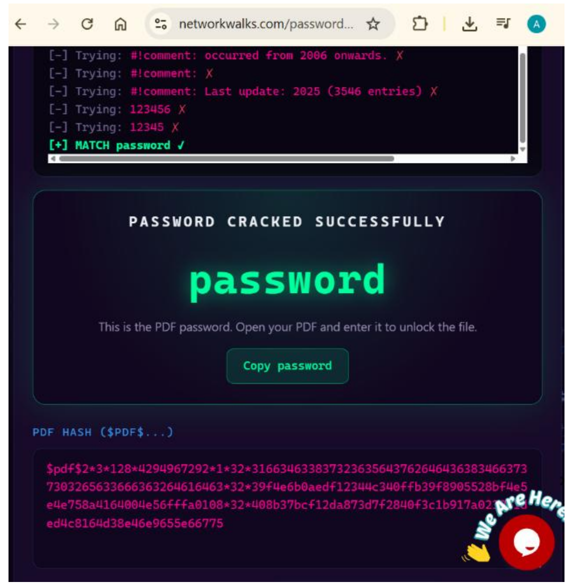


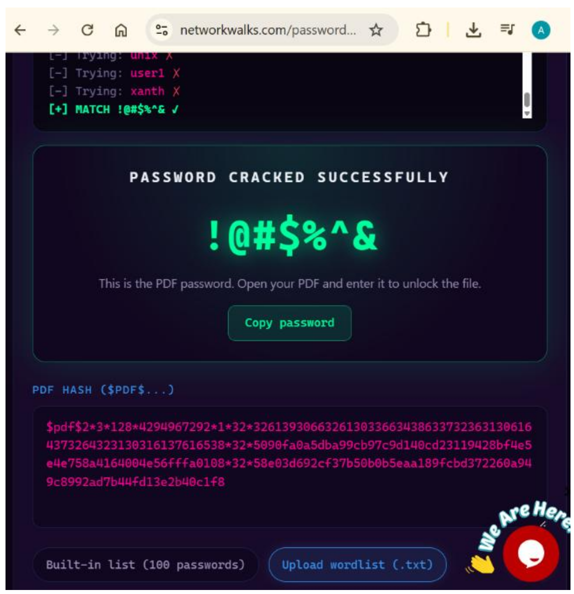




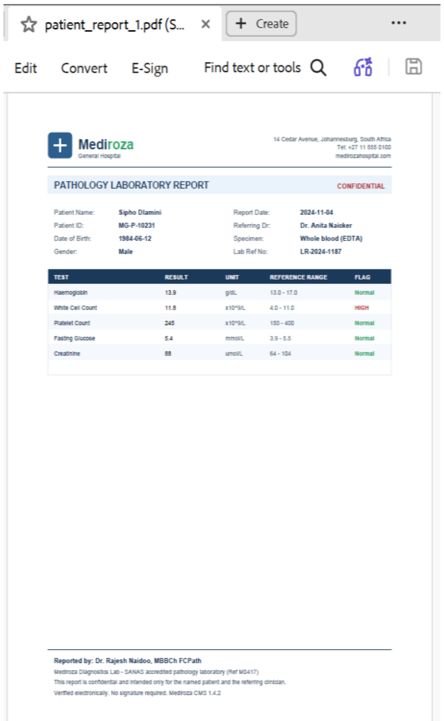
- 2. Submitted each hash to the NetworkWalks Password Cracker tool to recover the plaintext password.







- 3. Used the recovered passwords to decrypt each PDF and confirm access to the full patient lab report contents.



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name:	Sipho Dlamini	Report Date:	2024-11-04
Patient ID:	MG-P-10231	Referring Dr:	Dr. Anita Naicker
Date of Birth:	1984-06-12	Specimen:	Whole blood (EDTA)
Gender:	Male	Lab Ref No:	LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10^9/L	4.0 - 11.0	HIGH
Platelet Count	245	x10^9/L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Mediroza
General Hospital

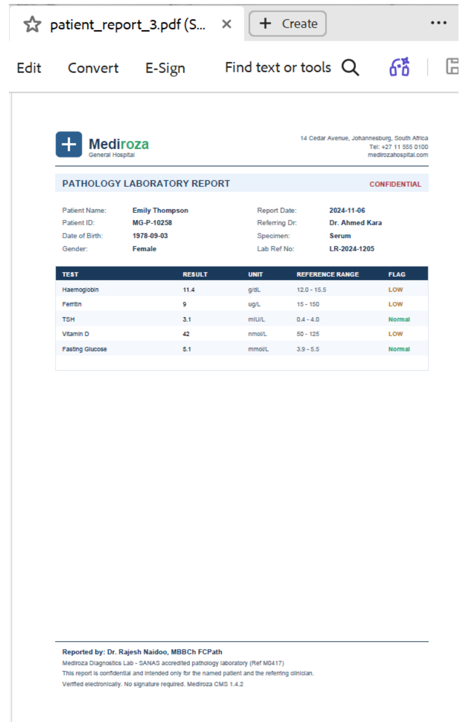
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name:	Priya Reddy	Report Date:	2024-11-05
Patient ID:	MG-P-10244	Referring Dr:	Dr. Johan van der Merwe
Date of Birth:	1991-02-28	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name:	Emily Thompson	Report Date:	2024-11-06
Patient ID:	MG-P-10258	Referring Dr:	Dr. Ahmed Kara
Date of Birth:	1978-09-03	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Impact

Weak, easily-crackable passwords provide only superficial protection. Once a file is obtained (as demonstrated in Finding 1), an attacker can trivially recover its contents using freely available cracking tools, fully defeating the intended confidentiality control and exposing detailed protected health information for each patient.

3.3 Finding 3 — Sensitive Path Disclosure via robots.txt (M3)

Severity: Low

Affected Component: /robots.txt

Description

The site's robots.txt file explicitly listed the sensitive directory names /patient/, /staff/, and /old/ under Disallow directives. While intended to prevent search engine indexing, this file instead provided a clear roadmap of sensitive paths for a malicious actor to investigate manually, directly contributing to the discovery of Finding 4 below.

Steps to Reproduce

- 1. Requested the robots.txt file directly.

Impact

On its own, this is a low-severity information disclosure issue. However, it materially assisted the identification of the critical exposure detailed in Finding 4, demonstrating how low-severity misconfigurations can compound into high-impact breaches when combined with other weaknesses.

3.4 Finding 4 — Exposed Directory Listings and Unauthenticated Database Backup Disclosure (M3)

Severity: Critical

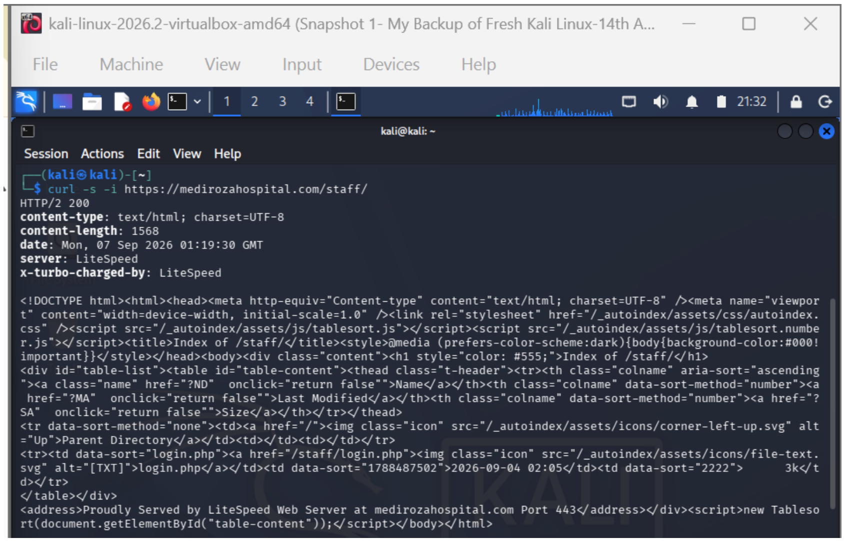
Affected Component: /staff/, /old/, /old/mediroza_db_backup_2019.sql

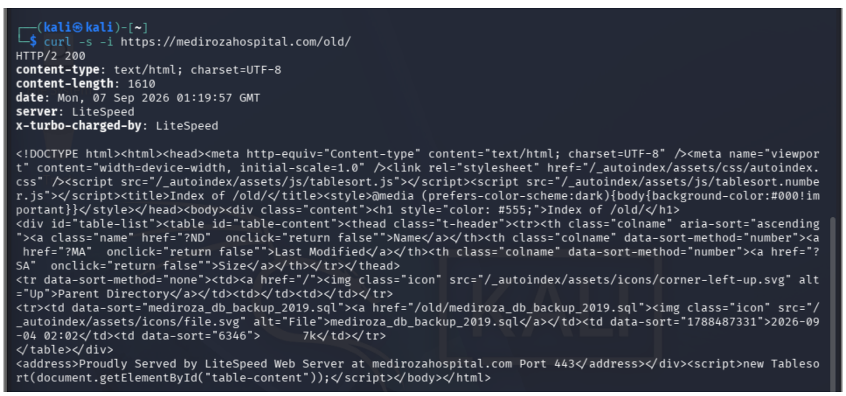
Description

The /staff/ and /old/ directories flagged in robots.txt were found to have directory listing (autoindexing) enabled and no access control in place. Browsing to /old/ revealed a publicly downloadable SQL database backup file, mediroza_db_backup_2019.sql, containing the hospital's internal HR and shareholder database in full, unencrypted plaintext.

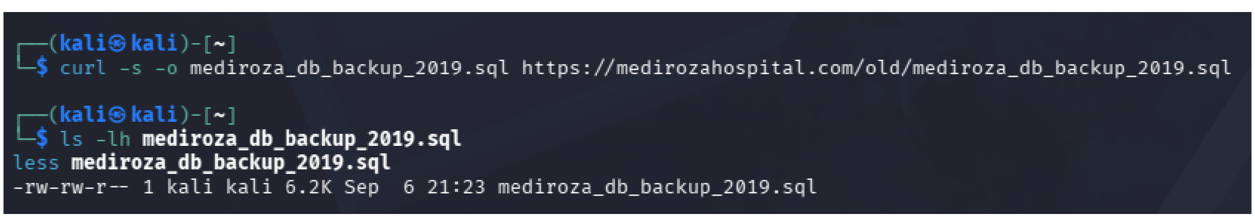
Steps to Reproduce

- 1. Requested the /staff/ and /old/ directories directly and confirmed directory listing was enabled on the server, exposing all files within.

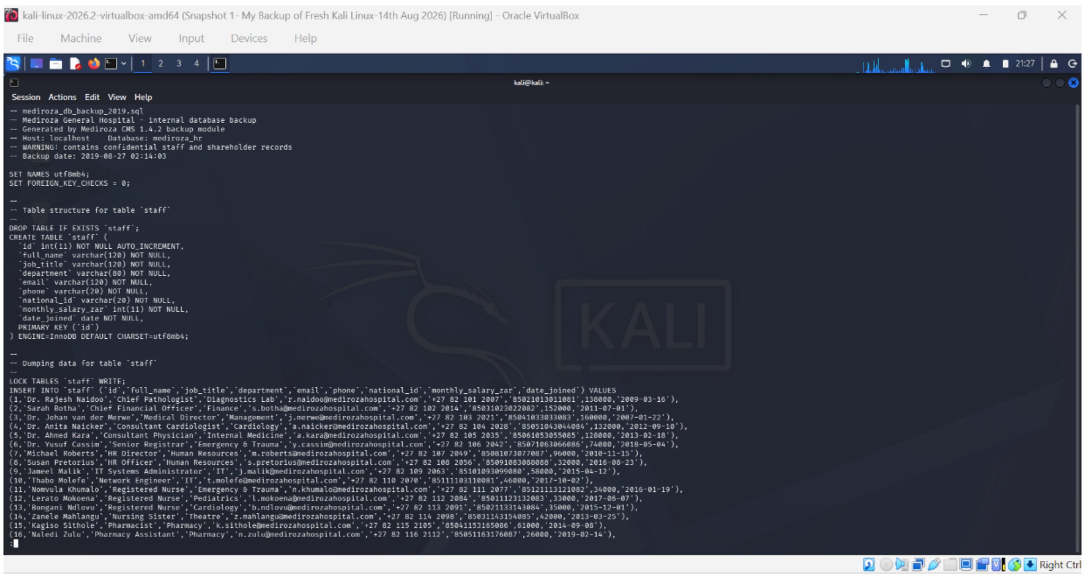


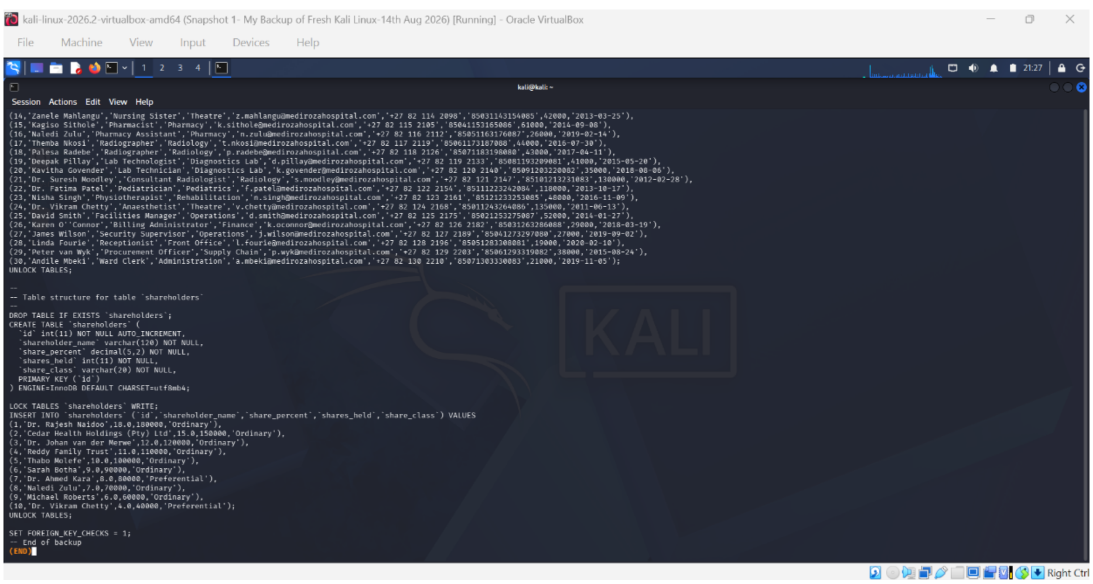


- 2. Downloaded the exposed SQL backup file directly, without any authentication.

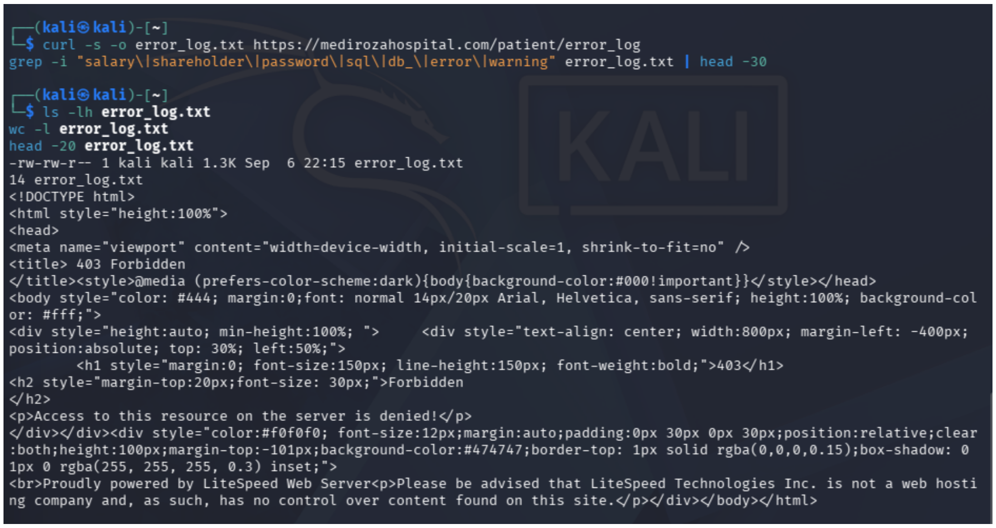


- 3. Reviewed the file header, confirming the file's own internal documentation acknowledges it contains confidential records.
- 4. Reviewed the staff table, revealing full name, job title, department, email, phone number, national ID number, and monthly salary for 30 employees.
- 5. Reviewed the shareholders table, revealing the complete equity ownership structure of the hospital.



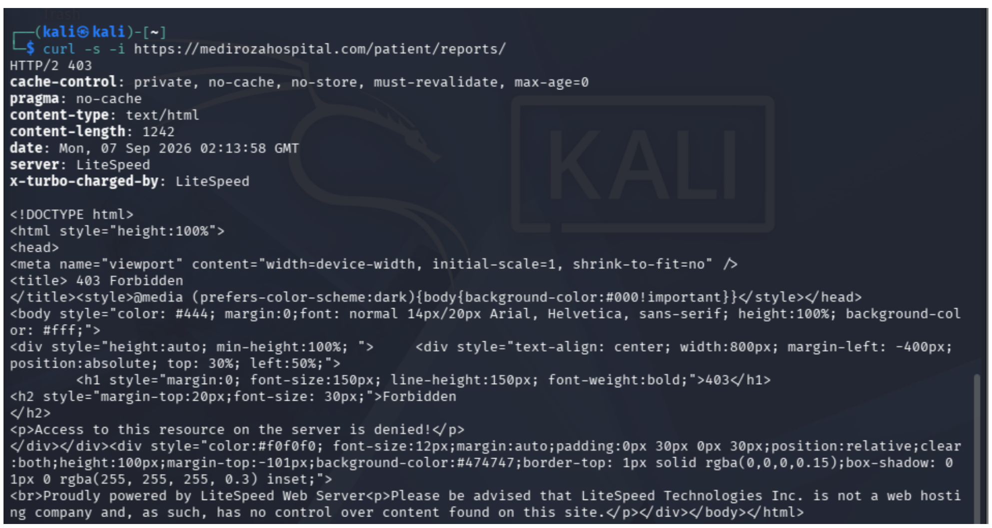


- 6. As a due-diligence check, verified whether related paths (/patient/reports/ and /patient/error_log) carried the same misconfiguration. Both were found to correctly return HTTP 403 Forbidden, confirming the exposure was isolated to /staff/ and /old/.



```
┌──(kali㉿kali)-[~]
└─$ curl -s -o error_log.txt https://medirozahospital.com/patient/error_log
grep -i "salary\|shareholder\|password\|sql\|db_\|error\|warning" error_log.txt | head -30

┌──(kali㉿kali)-[~]
└─$ ls -lh error_log.txt
wc -l error_log.txt
head -20 error_log.txt
-rw-rw-r-- 1 kali kali 1.3K Sep  6 22:15 error_log.txt
14 error_log.txt
<!DOCTYPE html>
<html style="height:100%">
<head>
<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no" />
<title> 403 Forbidden
</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</style></head>
<body style="color: #444; margin:0;font: normal 14px/20px Arial, Helvetica, sans-serif; height:100%; background-col
or: #fff;">
<div style="height:auto; min-height:100%; ">     <div style="text-align: center; width:800px; margin-left: -400px;
position:absolute; top: 30%; left:50%;">
        <h1 style="margin:0; font-size:150px; line-height:150px; font-weight:bold;">403</h1>
<h2 style="margin-top:20px;font-size: 30px;">Forbidden
</h2>
<p>Access to this resource on the server is denied!</p>
</div></div><div style="color:#f0f0f0; font-size:12px;margin:auto;padding:0px 30px 0px 30px;position:relative;clear
:both;height:100px;margin-top:-101px;background-color:#474747;border-top: 1px solid rgba(0,0,0,0.15);box-shadow: 0
1px 0 rgba(255, 255, 255, 0.3) inset;">
<br>Proudly powered by LiteSpeed Web Server<p>Please be advised that LiteSpeed Technologies Inc. is not a web hosti
ng company and, as such, has no control over content found on this site.</p></div></body></html>
```



```
┌──(kali㉿kali)-[~]
└─$ curl -s -i https://medirozahospital.com/patient/reports/
HTTP/2 403
cache-control: private, no-cache, no-store, must-revalidate, max-age=0
pragma: no-cache
content-type: text/html
content-length: 1242
date: Mon, 07 Sep 2026 02:13:58 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

<!DOCTYPE html>
<html style="height:100%">
<head>
<meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no" />
<title> 403 Forbidden
</title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</style></head>
<body style="color: #444; margin:0;font: normal 14px/20px Arial, Helvetica, sans-serif; height:100%; background-col
or: #fff;">
<div style="height:auto; min-height:100%; ">     <div style="text-align: center; width:800px; margin-left: -400px;
position:absolute; top: 30%; left:50%;">
        <h1 style="margin:0; font-size:150px; line-height:150px; font-weight:bold;">403</h1>
<h2 style="margin-top:20px;font-size: 30px;">Forbidden
</h2>
<p>Access to this resource on the server is denied!</p>
</div></div><div style="color:#f0f0f0; font-size:12px;margin:auto;padding:0px 30px 0px 30px;position:relative;clear
:both;height:100px;margin-top:-101px;background-color:#474747;border-top: 1px solid rgba(0,0,0,0.15);box-shadow: 0
1px 0 rgba(255, 255, 255, 0.3) inset;">
<br>Proudly powered by LiteSpeed Web Server<p>Please be advised that LiteSpeed Technologies Inc. is not a web hosti
ng company and, as such, has no control over content found on this site.</p></div></body></html>
```

Impact

This finding represents a critical and complete exposure of sensitive corporate and personal data. National ID numbers combined with salary and contact information create a severe identity-theft and targeted-fraud/phishing risk for all 30 staff members. Disclosure of the shareholder register exposes confidential corporate ownership information that could cause significant reputational and competitive harm to the hospital. The presence of a 2019 backup file also indicates a broader, longstanding data-retention and server-hygiene issue rather than an isolated one-off mistake.

4. Risk Rating

Each finding was rated using a standard qualitative risk matrix considering both the likelihood of exploitation and the impact of a successful attack. As this system processes protected health information (PHI) and confidential financial data, impact ratings have been weighted accordingly.

4.1 Rating Summary

#	Finding	Likelihood	Impact	Overall Risk
1	Authentication Bypass (SQLi) — Patient Portal	High	Critical	**Critical**
2	Weak/Crackable PDF Passwords	High	High	**High**
3	robots.txt Sensitive Path Disclosure	High	Low	**Low**
4	Exposed DB Backup via Directory Listing	High	Critical	**Critical**

4.2 Justification

Finding 1 — Critical

Likelihood is High because the vulnerability requires no special access and standard SQL injection payloads were sufficient to bypass authentication. Impact is Critical because it directly exposes protected health information for any patient in the system.

Finding 2 — High

Likelihood is High because the passwords were recoverable with freely available, publicly accessible cracking tools within a short timeframe. Impact is High rather than Critical because exploitation depends on first obtaining the file (via Finding 1).

Finding 3 — Low

Likelihood is High because the file is publicly accessible by design. Impact is Low in isolation, as robots.txt alone does not grant access to any data — it only discloses the existence of paths.

Finding 4 — Critical

Likelihood is High because the exposed directories required no authentication or special technique to access — only a standard HTTP request. Impact is Critical due to the combination of PII (national ID numbers), financial data (salaries), and confidential corporate ownership information (shareholder register) all being exposed in a single, unauthenticated file.

5. Recommendations and Remediation

5.1 Finding 1 — Authentication Bypass (SQL Injection)

- Use parameterised queries / prepared statements for all database interactions involving user input — never concatenate user input directly into SQL statements.
- Implement a Web Application Firewall (WAF) as a defence-in-depth measure to detect and block common injection payloads.
- Conduct a full source-code review of all authentication-related code paths, not just the login form, to identify similar patterns elsewhere in the application.
- Implement account lockout / rate limiting on the login endpoint to slow down automated attack attempts.

5.2 Finding 2 — Weak PDF Passwords

- Enforce a strong password policy for any password-protected documents (minimum length, complexity, no dictionary words or predictable patterns).
- Where possible, use PDF encryption with a strong, randomly generated per-document key rather than a user-memorable password, combined with secure key distribution (e.g., a patient portal download link rather than a static password).
- Consider encrypting sensitive documents at rest using AES-256 with keys managed via a proper key-management system rather than relying on PDF-native password protection alone.

5.3 Finding 3 — robots.txt Disclosure

- Remove sensitive or restricted path names from robots.txt entirely. robots.txt is a publicly readable file and should never be relied upon as an access-control mechanism.
- Enforce access control at the server/application layer (authentication, authorisation, and network-level restrictions) for any path that must remain private, regardless of whether it is listed in robots.txt.

5.4 Finding 4 — Exposed Directory Listings and Database Backup

- Immediately remove the mediroza_db_backup_2019.sql file (and any other backup files) from any publicly accessible web directory.
- Disable directory listing (autoindexing) server-wide unless explicitly required and reviewed for a specific, non-sensitive directory.
- Store all database backups outside of the web root, in a secured, access-controlled location (e.g., a dedicated backup server or encrypted cloud storage) that is never directly reachable via HTTP.
- Encrypt database backups at rest and restrict access via strong authentication and the principle of least privilege.
- Conduct a full audit of all web-accessible directories to identify and remove any other legacy, backup, or temporary files that may have been inadvertently exposed.
- Implement a formal data-retention and secure-deletion policy for old backups so files from as far back as 2019 are not left indefinitely accessible.

5.5 General Recommendations

- Conduct regular, periodic penetration testing and vulnerability scanning of all public-facing infrastructure.
- Implement centralised logging and monitoring/alerting for unusual access patterns, including repeated failed logins and access to sensitive file types (.sql, .bak, .zip) from the web server.
- Provide security awareness and secure-development training to development and IT staff, with particular focus on injection vulnerabilities (OWASP Top 10: A03 — Injection) and secure server configuration (OWASP Top 10: A05 — Security Misconfiguration).
- Given the exposure of PHI and PII, engage legal/compliance counsel to assess breach-notification obligations under applicable data protection legislation (e.g., POPIA).

6. Conclusion

This engagement identified critical vulnerabilities that, when chained together, allowed complete unauthenticated compromise of patient confidentiality along with exposure of sensitive staff and shareholder data. The root causes span both application-layer weaknesses (SQL injection, weak document encryption) and infrastructure-layer misconfiguration (directory listing, exposed backups). NetworkWalks recommends that Mediroza General Hospital treat the Critical findings in this report as an immediate priority and undertake a broader security review of its web infrastructure and secure development practices.

This project was conducted in a controlled environment for educational purposes only, under written authorisation from the client. These techniques must never be applied to any system without explicit written permission from the owner.